

Microsoft 365 Security Hardening Guide

10 critical controls to lock down your M365 tenant — based on CISA SCuBA baselines, CrowdStrike 2026 GTR, and real-world breach data.

80%+

of breaches involve
stolen credentials

Verizon DBIR 2025

82%

of detections are
malware-free

CrowdStrike 2026 GTR

99%+

of automated attacks
blocked by MFA

Microsoft

WEHACK

We hack you before they do.

Why Your M365 Tenant Is Already a Target

Attackers don't need malware anymore. They log in with stolen credentials, abuse legitimate tools, and move laterally through your cloud — all without triggering traditional alerts.

35%

of cloud incidents used
valid account abuse
CrowdStrike 2026 GTR

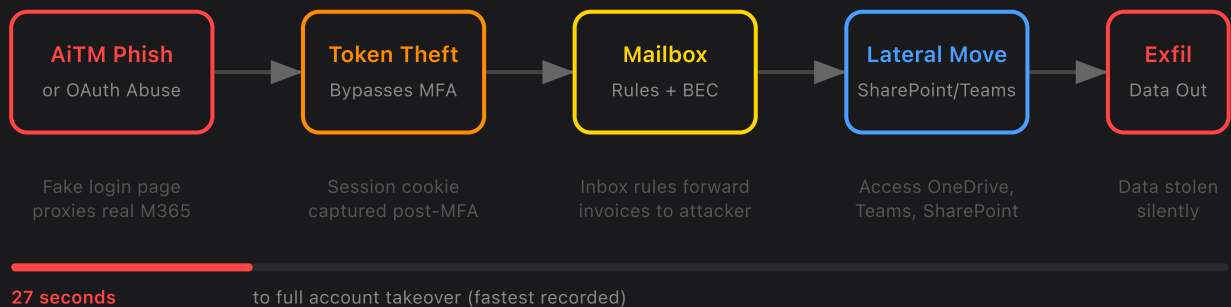
37%

increase in cloud-
conscious intrusions
CrowdStrike 2026 GTR

90%+

of incidents had
misconfigs enabling attack
Unit 42 2026

HOW ATTACKERS COMPROMISE M365 IN 2026



The AiTM Problem (December 2025 — Ongoing)

A sophisticated Adversary-in-the-Middle phishing campaign targeting M365 and Okta has been active since December 2025. The attack success rate exceeds 50%. Attackers impersonated 50+ applications and attempted to compromise nearly 3,000 M365 accounts across 900+ environments. Standard MFA doesn't stop it — only phishing-resistant methods (FIDO2 keys, certificate-based auth) and Conditional Access policies can.

Sources: KnowBe4, Proofpoint, ThreatLocker 2025

- **Identity weaknesses found in 90% of investigations.** Overprivileged accounts, weak passwords, lack of MFA, and shared credentials are how attackers escalate. [Unit 42 2026](#)
- **23% of incidents leveraged third-party SaaS apps** connected to your M365 tenant. Every OAuth app consent is a potential backdoor. [Unit 42 2026](#)

- **266% increase in state-nexus actors targeting cloud.** This isn't just criminal gangs — nation-state groups are actively targeting cloud tenants. [CrowdStrike 2026 GTR](#)

Critical M365 Hardening Steps

Prioritised by impact. Controls 1-3 alone block the majority of M365 attacks. Based on CISA SCuBA baselines and real-world incident response data.



Identity & Authentication

CONTROLS 1-4 • HIGHEST IMPACT

1

CRITICAL

Enforce MFA on Every Account

MFA blocks 99%+ of automated credential attacks. But basic SMS/app-push MFA is now bypassable via AiTM phishing (50%+ success rate in 2025 campaigns). Upgrade admin accounts to phishing-resistant MFA: FIDO2 security keys or certificate-based authentication. At minimum, deploy Microsoft Authenticator with number matching and additional context enabled.

Navigate: [Entra ID](#) → [Security](#) → [Authentication methods](#)

2

CRITICAL

Block Legacy Authentication

Legacy protocols (POP3, IMAP, SMTP basic auth) don't support MFA at all — they're a direct bypass. CISA calls this the single most important hardening step besides MFA. Microsoft has been deprecating basic auth since 2022, but many tenants still have it enabled for "compatibility." Check your sign-in logs — if you see legacy auth, kill it.

Navigate: [Entra ID](#) → [Security](#) → [Conditional Access](#) → [New policy](#) → [Block legacy auth](#)

3

CRITICAL

Deploy Conditional Access Policies

Conditional Access is the Zero Trust policy engine for Entra ID. It evaluates every sign-in against conditions (location, device, risk level) and enforces actions (require MFA, block access, limit session). CISA SCuBA mandates baseline policies covering: block legacy auth, require MFA for all users, require compliant devices for admins, and block sign-ins from high-risk locations.

Navigate: [Entra ID](#) → [Security](#) → [Conditional Access](#) → [Policies](#)

4

HIGH

Implement Privileged Identity Management (PIM)

Organisations using PIM experience 64% fewer security incidents. Global Admin should be assigned to no more than 2-4 accounts. Use just-in-time (JIT) activation so admin rights are

only active when needed, with approval workflows and time limits. Audit all existing admin accounts — most tenants have 3-5x more admins than necessary.

Navigate: [Entra ID](#) → [Identity Governance](#) → [Privileged Identity Management](#)

Quick Win: Security Defaults

If you're on Microsoft 365 Business Basic/Standard and don't have Entra ID P1/P2 for Conditional Access, at minimum enable Security Defaults. This forces MFA registration for all users and blocks legacy authentication. It's free and takes 30 seconds.

Navigate: [Entra ID](#) → [Properties](#) → [Manage Security Defaults](#) → [Enable](#)



Email & Threat Protection

CONTROLS 5-7 • EMAIL IS GROUND ZERO

5

CRITICAL

Configure Email Authentication (SPF, DKIM, DMARC)

Without proper email authentication, attackers can send emails that appear to come from your domain. SPF declares which servers can send as you. DKIM cryptographically signs your emails. DMARC tells receiving servers what to do with failures. Most NZ businesses have SPF but no DKIM or DMARC — leaving them wide open to impersonation. AI-generated phishing already has 4x the click-through rate of human-crafted emails.

Check yours: [nslookup -type=txt _dmarc.yourdomain.co.nz](#)

6

HIGH

Enable Safe Links & Safe Attachments

Part of Microsoft Defender for Office 365 (Plan 1 or 2). Safe Links rewrites URLs and checks them at click-time — protecting against delayed weaponisation where attackers send clean links that turn malicious hours later. Safe Attachments detonates files in a sandbox before delivery. With 141% increase in spam volume and 563% increase in fake CAPTCHA lures, this is essential.

Navigate: [Security](#) → [Policies](#) → [Threat Policies](#) → [Safe Links / Safe Attachments](#)

7

HIGH

Configure Anti-Phishing Policies

M365 Defender's anti-phishing policies include impersonation protection — it can flag emails where the sender's name matches your executives or domains but comes from an external address. Enable mailbox intelligence, spoof intelligence, and first-contact safety tips. With 56% of businesses experiencing phishing attacks and AI making them far more convincing, default policies aren't enough.

Navigate: [Security](#) → [Policies](#) → [Threat Policies](#) → [Anti-phishing](#)

4x

higher click rate for
AI-generated phishing

Programs.com

563%

increase in fake
CAPTCHA lures

CrowdStrike 2026 GTR

141%

increase in
spam volume

CrowdStrike 2026 GTR

Mailbox Rule Abuse — The Silent Backdoor

After compromising an M365 account, attackers create inbox rules that forward copies of all emails (especially invoices and financial messages) to an external address. They also create rules to move

security alerts to deleted items. These rules persist even after password reset. After any compromise: check Outlook rules, check mail flow rules in Exchange admin, and check delegated access permissions.



Data Protection & Visibility

CONTROLS 8–10 • KNOW WHAT'S HAPPENING

8

HIGH

Audit External Sharing & OAuth App Consents

23% of incidents leveraged third-party SaaS applications. Review all OAuth app consents in your tenant — every app a user approved has some level of access to your data. Restrict who can consent to apps (admin consent workflow). Audit SharePoint/OneDrive external sharing settings — most tenants default to "anyone with a link" which means any file shared externally is accessible to the entire internet.

Navigate: [Entra ID](#) → [Enterprise Applications](#) → [Consent and permissions](#)

9

HIGH

Enable Unified Audit Logging

If audit logging isn't enabled, you have zero visibility into who accessed what, when. This is the first thing incident responders check — and it's often not turned on. Enable unified audit log in Microsoft Purview. Set retention to at least 180 days (default is 90 for E3, 365 for E5). Without logs, you cannot investigate a breach, cannot prove compliance to the Privacy Commissioner, and cannot support insurance claims.

Navigate: [Purview](#) → [Audit](#) → [Start recording user and admin activity](#)

10

RECOMMENDED

Run the CISA SCuBA Assessment

CISA's ScubaGear is a free, open-source PowerShell tool that scans your M365 tenant against their Secure Configuration Baselines. It checks Entra ID, Exchange Online, SharePoint, OneDrive, Teams, Defender, and Power Platform. Produces an HTML report showing every misconfiguration with severity ratings. CISA BOD 25-01 now mandates this for US federal agencies — it's becoming the de facto M365 security standard globally.

Download: github.com/cisagov/ScubaGear



Data Loss Prevention (DLP) — Bonus Control

If you have M365 E3/E5 or Business Premium, enable DLP policies in Microsoft Purview. Set rules to detect and block sensitive data (credit card numbers, NZ IRD numbers, health information) from being shared externally via email, Teams, or SharePoint. With NZ Privacy Act 2020 mandatory breach reporting, preventing data leakage is better than reporting it.

Navigate: [Purview](#) → [Data Loss Prevention](#) → [Policies](#) → [Create](#)

64%

23%

\$900K

The 5-Minute M365 Security Audit

Print this page, work through each item, and tick it off. If you can't tick more than half — your tenant needs professional hardening.

-
- ☐ **MFA enabled for all users** (not just admins)
Entra ID → Users → Per-user MFA — or check Conditional Access
 - ☐ **Legacy authentication blocked**
Entra ID → Sign-in logs → filter "Client app" for legacy protocols
 - ☐ **Global Admin limited to ≤4 accounts**
Entra ID → Roles and administrators → Global administrator
 - ☐ **No shared admin passwords** (each admin has unique credentials)
If you have a "shared IT account" — that's a breach waiting to happen
 - ☐ **SPF, DKIM, and DMARC all configured**
Run: `nslookup -type=txt _dmarc.yourdomain.co.nz`
 - ☐ **Safe Links and Safe Attachments enabled**
Security → Policies → Threat Policies → verify policies exist and are ON
 - ☐ **External sharing restricted** (not "Anyone with a link")
SharePoint admin → Policies → Sharing — should be "New and existing guests" or stricter
 - ☐ **OAuth app consent restricted to admins**
Entra ID → Enterprise apps → Consent settings → "Do not allow user consent"
 - ☐ **Unified audit log enabled**
Purview → Audit → verify "Start recording" is active
 - ☐ **No suspicious mailbox forwarding rules**
Exchange admin → Mail flow → Rules — also check per-user Outlook rules
-

Your Score: ____ / 10

8-10: Strong foundation — consider a pentest to validate. 5-7: Gaps exist that attackers will find. 0-4: Your tenant is likely already compromised or trivially exploitable.

Why This Matters for NZ Businesses

New Zealand isn't a backwater for cybercrime. It's a soft target with valuable data and underspent defences.

\$7.8M

lost in Q1 2025 alone
(14.7% increase)

CERT NZ / NCSC

26K

NZers contacted about
Lumma Stealer malware

NCSC

92

NZ/AU business credentials
sold on dark web in 2025

NCSC

- **~1 nationally significant cyber incident per day** handled by NCSC. 300+ required specialist investigation in 2024/25. [NCSC](#)
- **25% of nationally significant incidents linked to state-sponsored actors.** NZ is part of Five Eyes — which makes Kiwi businesses targets for Chinese and Russian APTs. [NCSC Q1 2025](#)
- **Phishing/credential harvesting up 15% to 440 reports in Q1 2025.** Most of these target M365 accounts — it's the single most common attack vector for NZ businesses. [CERT NZ](#)
- **40% of NZ SMBs say a \$100K attack would shut them down.** Yet most haven't reviewed their M365 security settings since initial setup. [VikingCloud 2026](#)
- **Privacy Act 2020 mandatory breach reporting.** If personal data is compromised because your M365 wasn't properly secured, you must notify the Privacy Commissioner. Fines up to \$10,000 plus enforcement action. Negligent security configuration will not be a good look. [Privacy Act 2020](#)

ManageMyHealth — What Happens When Cloud Security Fails

In January 2026, the "Kazu" threat group breached ManageMyHealth, exfiltrating 108GB of sensitive health data — 400,000+ documents including clinical notes, lab results, and medical photographs for 120,000+ patients. The Privacy Commissioner launched a formal inquiry. The \$60K ransom demanded was insignificant compared to the regulatory, legal, and reputational damage. The attack vector? Inadequate access controls and cloud security configuration.

M365 Is Ground Zero for NZ SMBs

Microsoft 365 is the default productivity platform for New Zealand businesses. Your email, files, contacts, Teams conversations, and SharePoint sites all live there. When an attacker compromises

your M365 tenant, they don't just get email — they get everything. And with 82% of detections being malware-free (attackers just log in), your antivirus won't save you. Only proper configuration will.

What We Find When We Test M365 Tenants

As ethical hackers who test M365 environments for a living, these are the misconfigurations we exploit most often. Every item below is something we've successfully used in real penetration tests — and something attackers are using right now.

#1 Finding: Overprivileged Service Accounts with No MFA

Almost every tenant has service accounts (backup tools, scanners, CRM integrations) that are Global Admin or Exchange Admin with basic passwords and no MFA. These are the first accounts we target. Attackers use credential stuffing and password spraying against these because they know service accounts are rarely monitored.

Fix: Audit all accounts with admin roles. Convert service accounts to managed identities where possible. Enforce MFA on ALL admin accounts with zero exceptions. Use Entra ID PIM for just-in-time access.

#2 Finding: Mailbox Forwarding Rules to External Addresses

We frequently find mailbox rules forwarding email to external addresses — often left behind from a previous compromise that was never fully remediated. Attackers create rules that forward copies of invoices and financial emails to their own inbox, then wait for the right moment to inject a payment redirect.

Detection command: `Get-TransportRule | Where-Object {$_.RedirectMessageTo -ne $null}` — and check per-user Outlook rules via `Get-InboxRule` for all users. Look for rules that delete or move messages to unusual folders.

#3 Finding: OAuth App Consent Grants to Unknown Applications

Users click "Allow" on OAuth consent prompts without reading them. We've found apps with Mail.ReadWrite, Files.ReadWrite.All, and User.Read.All permissions granted by regular users — giving third-party apps full access to email, files, and directory data. This is how the "OAuth device code phishing" campaigns work — Russia-linked actors used this exact technique against M365 tenants in late 2025.

Audit: Entra ID → Enterprise Applications → filter by "User consent" → review permissions. Restrict consent to admin-only. Review all apps with Graph API: `GET /servicePrincipals?$select=displayName,appId,oauth2PermissionGrants`

#4 Finding: Audit Logs Disabled or Insufficient Retention

When we ask clients to provide audit logs for our testing period, ~30% discover their unified audit log was never enabled. Without logs, you cannot detect lateral movement, data exfiltration, or identify

which accounts were compromised during an incident. E3 tenants default to 90-day retention — barely enough for investigation. Many breaches aren't discovered for months.

Verify: `Search-UnifiedAuditLog -StartDate (Get-Date).AddDays(-1) -EndDate (Get-Date)` — if this returns nothing, logging is disabled. Enable immediately in Purview and increase retention to maximum (365 days for E5, consider log export for E3).

#5 Finding: SharePoint/OneDrive "Anyone with a Link" Sharing

Default sharing is often set to "Anyone" — meaning a shared link works for anyone on the internet, no authentication required. We've found client contracts, employee records, financial spreadsheets, and technical architecture documents accessible via public links. Combine this with AI OSINT scraping and an attacker can harvest sensitive documents before launching their social engineering campaign.

Fix: SharePoint admin → Policies → Sharing → set to "New and existing guests" at minimum. Review existing links: `Get-SPOSite | Select Url, SharingCapability` — and audit active sharing links.

Our M365 Security Assessment Checks 47 Configuration Points

Including: Conditional Access gaps, stale admin accounts, mail flow rules, external forwarding, DLP policy coverage, eDiscovery permissions, Teams guest access, Power Platform data connectors, sensitivity labelling gaps, and tenant-wide sharing defaults.

WHAT'S NEXT

Don't Guess. Get Tested.

This guide shows you what to check. A penetration test shows you what attackers actually find. We test your M365 configuration the same way real adversaries would.

Get Your M365 Tenant Assessed

We run CISA SCuBA scans, test your Conditional Access policies, check for AiTM vulnerability, audit OAuth app consents, and verify your email authentication — then give you a prioritised remediation report.

Take Your Free Security Score →

Every business has different security challenges. Book a free 15-minute chat and we'll recommend the right approach — no obligation.

Mustafa Demirsoy
Founder & Hacker, WeHack

wehack.co.nz | info@wehack.co.nz | 022 091 7242
148 Durham Street, Tauranga 3110